the holder’s employer, certification status, or project role. This separation keeps policies simple and allows ACME to manage its trust mechanisms independently of its authorization logic.

Before evaluation, the PEP normalizes the extracted claims into an internal attribute schema. This reflects the approach described in earlier chapters for device posture and other contextual signals. A claim such as `employer=AuditsRUs` or `certification=CISA-R` becomes an attribute on the principal. The responsibility for verifying credential signatures, checking issuer trust, and ensuring that the claims come from authorized sources lies with the PEP and the mapping layer that prepares the request the PDP receives.

Policies can then reference these attributes in the same way they reference any other contextual information. A policy might require that the principal’s employer be on the list of trusted auditing firms or that the principal hold a specific certification issued by an accredited authority. More complex policies may combine credential-derived attributes with session information, environmental conditions, or resource metadata. The key point is that verifiable credentials integrate seamlessly into ACME’s policy model because the claims they contain become attributes evaluated at decision time.

When Angela accesses the systems where the audit-relevant documents and logs are stored, the PEP extracts the claims from her presentation, normalizes them, and evaluates policies like those shown in the following examples. The policies do not need to know how those claims were obtained or which credentials were combined to produce them.

16.6.1 Allow access only to auditors from accredited firms

This policy illustrates how ACME ensures that only auditors employed by recognized firms and holding the proper certification can access audit logs. It relies on two VC-derived attributes: the principal’s employer and their certification status.